

# Lmarcho Commerce MCP User Guide

Module: **Lmarcho\_CommerceMcp** | Version: **0.9.0** | Audience: Magento administrators and AskRAG integration operators

## 1. Overview

Lmarcho Commerce MCP adds an authenticated, read-only Model Context Protocol endpoint to Magento Open Source or Adobe Commerce. The endpoint allows an approved AskRAG backend to fetch live storefront information such as product prices, stock status, media, categories, promotions, and customer-authorized order status.

The module does not create or edit products, carts, customers, orders, coupons, or administrator records. It is designed for customer-facing chat experiences where stable product and content knowledge is combined with live commerce data from Magento.

## 2. Main Features

- Authenticated MCP endpoint at `/commerce-mcp`.
- Named client tokens that are shown once, stored hashed, rotated, and revoked.
- Store-code allow-listing so each request is scoped to approved storefronts.
- Live product hydration with public price, salability, URLs, images, gallery, attributes, options, and bounded variants.
- Product search, category browsing, related products, upsells, and cross-sells.
- Public promotion summaries with coupon disclosure controlled by an allow-list.
- Aggregate product popularity for ranking general product suggestions.
- Logged-in customer order status through short-lived Magento-issued assertions.
- Guest order verification with order number plus billing email or phone.
- Read-only cart and purchase-history summaries for asserted logged-in customers.
- Request limits, response limits, rate limits, and sanitized correlation logging.

## 3. Requirements

| Requirement    | Supported value                                                                                    |
|----------------|----------------------------------------------------------------------------------------------------|
| Magento        | Magento Open Source or Adobe Commerce using Magento framework <code>&gt;=103.0 &lt;104</code> .    |
| PHP            | 8.1, 8.2, or 8.3.                                                                                  |
| Inventory      | Magento Inventory Sales API for salability checks.                                                 |
| AskRAG backend | A tenant configuration that supports Magento MCP health checks, live data, and order verification. |
| Transport      | HTTPS is expected for shared and production environments.                                          |

## 4. Installation

### Composer Installation

```
composer require lmarcho/module-commerce-mcp
php bin/magento module:enable Lmarcho_CommerceMcp
php bin/magento setup:upgrade
php bin/magento cache:clean config full_page
```

### Production Mode

```
php bin/magento setup:di:compile
php bin/magento setup:static-content:deploy -f
php bin/magento cache:clean
```

The MCP endpoint is disabled by default after installation. Configure allowed store codes and create an MCP client token before enabling it.

## 5. Magento Admin Configuration

Open **Stores > Configuration > Services > Commerce MCP**. The configuration is global because the MCP endpoint is intentionally scoped by explicit store-code allow-listing.

| Field                    | Purpose                                                                                                             |
|--------------------------|---------------------------------------------------------------------------------------------------------------------|
| Enable MCP Endpoint      | Turns the endpoint on after setup is complete. Keep disabled until token and store-code configuration is ready.     |
| Maximum Request Size     | Rejects oversized MCP requests before tool execution.                                                               |
| Maximum Response Size    | Prevents overly large tool responses.                                                                               |
| Allowed Store Codes      | Comma-separated active storefront codes, for example <code>default,en_us</code> . The admin store is never allowed. |
| Maximum SKUs Per Request | Limits batched product hydration.                                                                                   |
|                          |                                                                                                                     |

|                                        |                                                                                                                      |
|----------------------------------------|----------------------------------------------------------------------------------------------------------------------|
| Maximum Gallery Images Per Product     | Bounds product media payloads.                                                                                       |
| Maximum Variants Per Product           | Bounds configurable child variant data.                                                                              |
| Fallback to Parent Variant Image       | Uses parent media when a child variant has no image.                                                                 |
| Maximum Search Results                 | Limits native search and category product responses.                                                                 |
| Maximum Related Products Per Link Type | Limits related, upsell, and cross-sell responses.                                                                    |
| Maximum Promotions Per Request         | Limits public promotion summaries.                                                                                   |
| Public Chat Coupon Codes               | Comma-separated coupon codes approved for chatbot display. Codes not listed here are hidden.                         |
| Customer Assertion Lifetime            | Short-lived logged-in customer proof, clamped to 60 through 300 seconds.                                             |
| Customer Assertion Signing Key         | Optional dedicated HMAC secret. If empty, Magento's crypt key is used.                                               |
| Request Rate Limit Per Minute          | Per-client general MCP request limit.                                                                                |
| Order Status Rate Limit Per Minute     | Stricter order-status request limit.                                                                                 |
| Tracking URL Templates                 | Optional HTTPS carrier templates, one per line, for example<br>ups=https://carrier.example/track/{tracking_number} . |

## 6. Access Token Setup

Tokens identify server-to-server MCP clients. Tokens are displayed only once and are stored hashed in Magento. Store the token in the AskRAG tenant's Magento integration settings.

### Create a Client Token

```
php bin/magento commerce-mcp:client:create "AskRAG Laravel"
```

Optional UTC expiry:

```
php bin/magento commerce-mcp:client:create "AskRAG Laravel" --expires-at="2026-12-31 23:59:59"
```

### Rotate or Revoke a Client

```
php bin/magento commerce-mcp:token:rotate "AskRAG Laravel"
php bin/magento commerce-mcp:client:revoke "AskRAG Laravel"
```

### List Available Tools

```
php bin/magento commerce-mcp:tools:list
```

## 7. AskRAG Tenant Configuration

Configure the Magento integration in the AskRAG backend or tenant admin:

| Setting      | Value                                                                             |
|--------------|-----------------------------------------------------------------------------------|
| MCP endpoint | https://STORE-DOMAIN/commerce-mcp                                                 |
| MCP token    | The generated token beginning with <code>lmcp_</code> .                           |
| Store code   | The configured Magento storefront code, usually <code>default</code> .            |
| Driver mode  | Use <code>shadow</code> during rollout, then <code>mcp</code> after verification. |

## 8. Health Check

From the AskRAG backend, run:

```
php artisan commerce:mcp:health TENANT_SLUG --platform=magento --json
```

The health check should confirm:

- MCP initialization succeeds.
- Required tools are present.
- The configured store code resolves correctly.
- Schema and protocol versions are supported.
- Order tools are present when order status is enabled in the tenant workflow.

## 9. Customer-Facing Chat Behavior

### Product and Category Questions

AskRAG may use vector retrieval to discover candidate products, then call Magento MCP for current price, stock, media, product URLs, categories, and variant data. Product cards in the widget are built by AskRAG from the live MCP payload.

### Promotion Questions

The MCP promotion tool returns public promotion summaries. Coupon codes are only shown when the code appears in the Public Chat Coupon Codes allow-list. Catalog discounts already reflected in product final prices are not added a second time.

### Logged-In Customer Order Status

Logged-in customers can ask about their own orders. Magento issues a short-lived same-origin customer assertion from `/commerce-mcp/customer/assertion`. AskRAG uses the assertion to call `get_order_status`. The response excludes billing address, shipping address, email, telephone, payment details, invoices, credit memos, and internal comments.

### Guest Order Verification

Guests see a compact widget verification form. The form asks for order number and billing email or phone. That verification data is posted to the backend verification endpoint and is not sent through normal chat text or included in an LLM prompt.

Failed guest checks return a generic message so order numbers cannot be enumerated. Repeated failures are subject to order-status rate limits.

## 10. Security and Privacy Boundaries

- All MCP tools are read-only.
- Public product and promotion tools return storefront-visible data.
- Product cost, source-level warehouse quantities, admin records, customer lookup, arbitrary order search, payment data, and write operations are not exposed.
- Browser-provided customer IDs, emails, and login flags do not authorize customer-specific data.
- Logged-in customer order status requires a Magento-issued assertion.
- Guest order verification requires order number plus billing email or phone.
- Access tokens are shown once and stored hashed.
- Correlation IDs are used for troubleshooting without logging secrets.
- Do not place MCP tokens in browser JavaScript, public HTML, logs, screenshots, or ticket comments.

## 11. Troubleshooting

| Symptom                                            | Check                                                                                                 |
|----------------------------------------------------|-------------------------------------------------------------------------------------------------------|
| Endpoint returns disabled or unavailable response. | Confirm Enable MCP Endpoint is set to Yes and run <code>php bin/magento cache:clean config</code> .   |
| Authentication fails.                              | Confirm the token was copied exactly, has not expired, and has not been revoked or rotated.           |
| Store context fails.                               | Confirm the requested store code is active and listed in Allowed Store Codes.                         |
| Product card has no image.                         | Confirm the product has a storefront-visible base image or gallery image for the selected store view. |
|                                                    |                                                                                                       |

|                                           |                                                                                                                       |
|-------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| Price or stock differs from expectations. | Confirm the selected store view, website, currency, catalog price rules, and MSI salability configuration.            |
| Coupon code is not shown.                 | Add only public, approved coupon codes to Public Chat Coupon Codes and clear config cache.                            |
| Logged-in order status fails.             | Confirm the customer is logged in to the same Magento store and the assertion endpoint is reachable from the browser. |
| Guest order verification fails.           | Confirm the order number and billing email or phone match the order and store view.                                   |

## 12. Upgrade and Maintenance

1. Back up the Magento codebase and database according to store policy.
2. Update the package through Composer.
3. Run `php bin/magento setup:upgrade`.
4. Run production compile and static-content deployment when required.
5. Run `php bin/magento cache:clean`.
6. Run the AskRAG MCP health check.
7. Review token age and rotate tokens when operational policy requires it.

Data patches backfill newly approved read-only tools into the default read-only role. If a role was manually customized, review allowed tools after upgrade.

## 13. Manual Verification Checklist

- Module installs with Composer and `setup:upgrade`.
- Magento compiles in production mode.
- Endpoint remains disabled until configured.
- Allowed store codes reject unapproved store codes.
- Client token can be created, rotated, and revoked.
- Health check succeeds for the configured AskRAG tenant.
- Product cards show current price, stock status, image, URL, and variants where applicable.
- Promotion questions show only public promotion details and approved coupon codes.
- Logged-in customer can retrieve only their own order status.
- Guest order verification works with matching order number and billing email or phone.
- Failed order verification does not disclose whether the order number exists.
- Logs do not contain MCP tokens, assertions, billing email, phone, addresses, or payment data.

## 14. Support Information

For operational issues, collect the Magento version, PHP version, module version, store code, AskRAG tenant slug, MCP health-check output, and the Magento correlation ID from the failing request. Do not include access tokens, customer assertions, billing email, phone numbers, addresses, or payment details in support notes.